

Vulnerability: Content Security Policy (CSP) Bypass

You can include scripts from external sources, examine the Content Security Policy and enter a URL to include here:

Include

As Pastebin and Hastebin have stopped working, here are some scripts that may, or may not help.

- <https://digi.ninja/dvwa/alert.js>
- <https://digi.ninja/dvwa/alert.txt>
- <https://digi.ninja/dvwa/cookie.js>
- https://digi.ninja/dvwa/forced_download.js
- https://digi.ninja/dvwa/wrong_content_type.js

Pretend these are on a server like Pastebin and try to work out why some work and some do not work. Check the help for an explanation if you get stuck.

More Information

- [Content Security Policy Reference](#)
- [Mozilla Developer Network - CSP: script-src](#)
- [Mozilla Security Blog - CSP for the web we have](#)

Module developed by [Digininja](#).

Authorisation Bypass

page as admin user, everything is alright

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript Attacks

Authorisation Bypass

Open HTTP Redirect

Cryptography

API

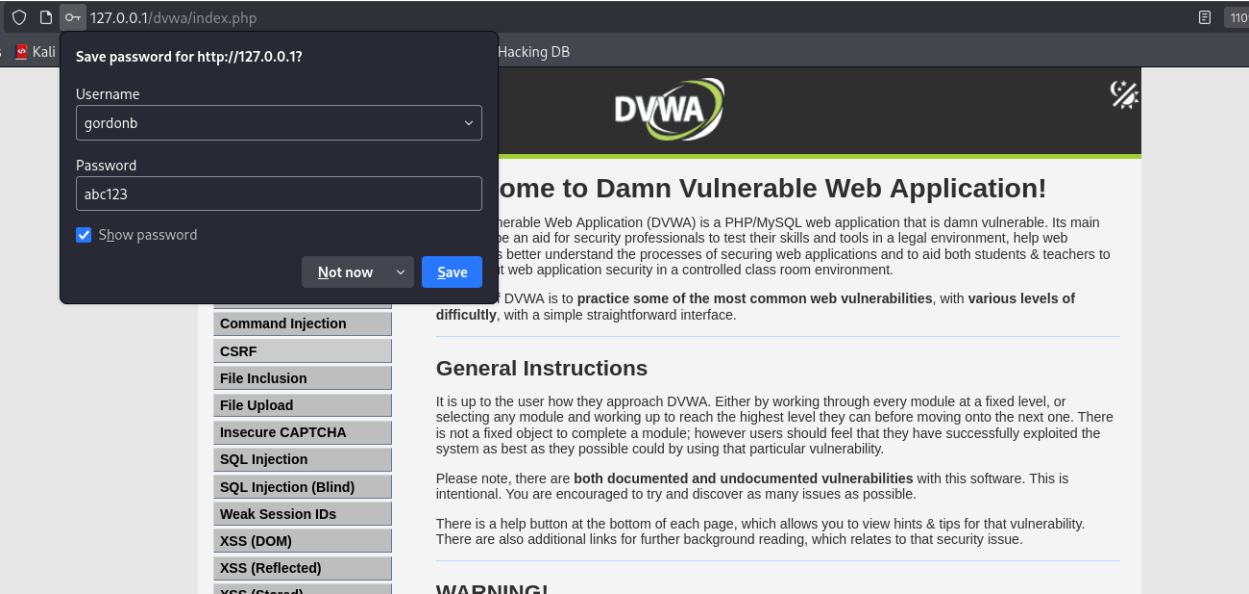
Vulnerability: Authorisation Bypass

This page should only be accessible by the admin user. Your challenge is to gain access to the features using one of the other users, for example *gordonb* / *abc123*.

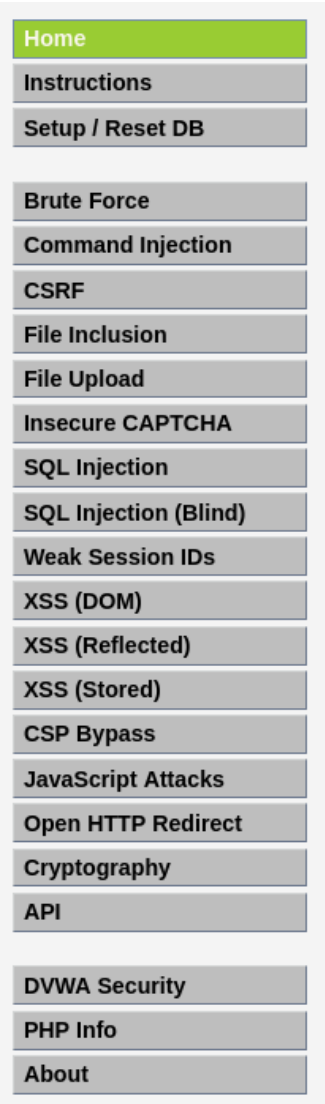
Welcome to the user manager, please enjoy updating your user's details.

ID	First Name	Surname	Update
5	Bob	Smith	Update
4	Pablo	Picasso	Update
3	Hack	Me	Update
2	Gordon	Brown	Update
1	admin	admin	Update

Now we have to login as gordonb



And we can see that as gordonb we don't have “**Authorisation Bypass**” menu option because non-admin users don't have that menu option



but if i copy “/vulnerabilities/authbypass” part and paste in url link instead “/index” we can see and work with that page as gordonb

127.0.0.1/dvwa/vulnerabilities/authbypass/

Kali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DB

DVWA

HomeInstructionsSetup / Reset DB

Brute ForceCommand InjectionCSRFFile InclusionFile UploadInsecure CAPTCHASQL InjectionSQL Injection (Blind)Weak Session IDsXSS (DOM)XSS (Reflected)XSS (Stored)CSP BypassJavaScript AttacksOpen HTTP RedirectCryptographyAPI

Vulnerability: Authorisation Bypass

This page should only be accessible by the admin user. Your challenge is to gain access to the features using one of the other users, for example *gordonb* / *abc123*.

Welcome to the user manager, please enjoy updating your user's details.

ID	First Name	Surname	Update
5	Bob	Smith	Update
4	Pablo	Picasso	Update
3	Hack	Me	Update
2	Gordon	Brown	Update
1	admin	admin	Update

open http redirect

127.0.0.1/dvwa/vulnerabilities/open_redirect/source/info.php?id=1 HTTP/1.1

Cache-Control: max-age=0

sec-ch-ua: "Chromium";v="109", "Not A Brand";v="99"

sec-ch-ua-mobile: ?0

sec-ch-ua-platform: "Linux"

Accept-Language: en-US,en;q=0.9

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/109.0.0.0 Safari/537.36

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,f/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Sec-Fetch-Site: same-origin

Sec-Fetch-Mode: navigate

Sec-Fetch-User: ?1

Sec-Fetch-Dest: document

Referer: http://127.0.0.1/dvwa/vulnerabilities/open_redirect/

Accept-Encoding: gzip, deflate, br

Cookie: securityimpossible: PHPSESSID=0c39f760e332171e635ac90b2a20c2a

Connection: keep-alive

Response

Vulnerability: Open HTTP Redirect

HomeInstructionsSetup / Reset DB

Brute ForceCommand InjectionCSRFFile InclusionFile UploadInsecure CAPTCHASQL InjectionSQL Injection (Blind)Weak Session IDsXSS (DOM)XSS (Reflected)XSS (Stored)CSP BypassJavaScript AttacksAuthorisation BypassOpen HTTP RedirectCryptographyAPI

Hacker Quotes

Why did he come to you?
I got a record. I was Zero Cool
Zero Cool. Crashed 1507 systems in one day, biggest crash in history. front page, New York Times August 10th 1988.
[Back](#)

More Information

- [OWASP Unvalidated Redirects and Forwards Cheat Sheet](#)
- [WSTG - Testing for Client-side URL Redirect](#)
- [More - CVE-2018-1686, Redirection to Untrusted Site \(Open Redirect\)](#)